

Лабораторна робота. Використання Wireshark для дослідження HTTP та HTTPS трафіку

Цілі та задачі

Частина 1. Захоплення та перегляд трафіку HTTP

Частина 2. Захоплення та перегляд трафіку HTTPS

Довідкова інформація / Сценарій

Протокол передавання гіпертекстових повідомлень (HTTP) - це протокол прикладного рівня, який представляє дані через веб-браузер. HTTP не забезпечує захисту даних, якими обмінюються два взаємодіючі пристрої.

В HTTPS для шифрування використовується математичний алгоритм. Цей алгоритм приховує справжній зміст даних, якими обмінюється. Це робиться за допомогою сертифікатів, які можна переглянути пізніше в цій лабораторній роботі.

Незалежно від HTTP або HTTPS, рекомендується обмінюватися даними лише з веб-сайтами, яким ви довіряєте. Той факт, що сайт використовує HTTPS, не означає, що він надійний. Зловмисники зазвичай використовують HTTPS, щоб приховати свою діяльність.

У цій лабораторній роботі ви будете досліджувати і захоплювати HTTP і HTTPS трафік за допомогою Wireshark.

Необхідні ресурси

- CyberOps Workstation VM
- Під'єднання до Інтернету

Інструкції

Частина 1: Захоплення та перегляд трафіку HTTP

У цій частині ви будете використовувати **tcpdump** для захоплення вмісту HTTP-трафіку. Ви будете використовувати параметри команд для збереження трафіку в файл захоплення пакетів (pcap). Ці записи потім можна проаналізувати за допомогою різних додатків, які читають файли pcap, включаючи Wireshark.

Крок 1: Запустіть віртуальну машину та увійдіть до системи

Запустіть CyberOps Workstation VM. Використовуйте такі облікові дані користувача:

Ім'я користувача: **analyst**

Пароль: **cyberops**

Крок 2: Відкрийте термінал і запустіть tcpdump.

- Відкрийте застосунок терміналу і введіть команду **ip address**.

```
[analyst@secOps ~]$ ip address
```

- b. Перелічіть інтерфейси і їх IP-адреси, що відображаються у вихідних даних команди **ip address**.

lo (loorback): Локальний інтерфейс зі стандартною IP-адресою 127.0.0.1.

enp0s3 (Ethernet): Основний мережевий інтерфейс, який отримує IP-адресу від локальної мережі (192.168.1.105).

- c. Перебуваючи в застосунку терміналу, введіть команду **sudo tcpdump -i enp0s3 -s 0 -w httpdump.pcap**. Коли буде запропоновано, введіть пароль **cyberops** для користувача **analyst**.

```
[analyst@secOps ~]$ sudo tcpdump -i enp0s3 -s 0 -w httpdump.pcap
[sudo] password for analyst:
tcpdump: listening on enp0s3, link-type EN10MB (Ethernet), capture size 262144 bytes
```

Ця команда запускає tcpdump і записує мережевий трафік на інтерфейсі **enp0s3**.

Параметр **-i** для команди дозволяє вказати інтерфейс. Якщо параметр не вказано, tcpdump буде захоплювати весь трафік на всіх інтерфейсах.

Параметр команди **-s** визначає довжину знімка для кожного пакета. Ви повинні обмежити snaplen найменшим числом, яке буде захоплювати інформацію про протокол, яка вас цікавить. Встановлення snaplen на 0 встановлює значення за замовчуванням 262144 для зворотної сумісності з останніми старими версіями tcpdump.

Параметр команди **-w** використовується для запису результату команди tcpdump в файл. Додавання розширення .pcap гарантує, що операційні системи та програми зможуть читати файл. Весь записаний трафік буде роздрукований в файл httpdump.pcap в домашньому каталозі користувача **analytics**.

Використовуйте сторінки довідки для tcpdump, щоб визначити використання параметрів команди **-s** і **-w**.

- d. Відкрийте веб-браузер з панелі запуску в VM робочої станції CyberOps. Перейдіть до **<http://www.altoromutual.com/login.jsp>**

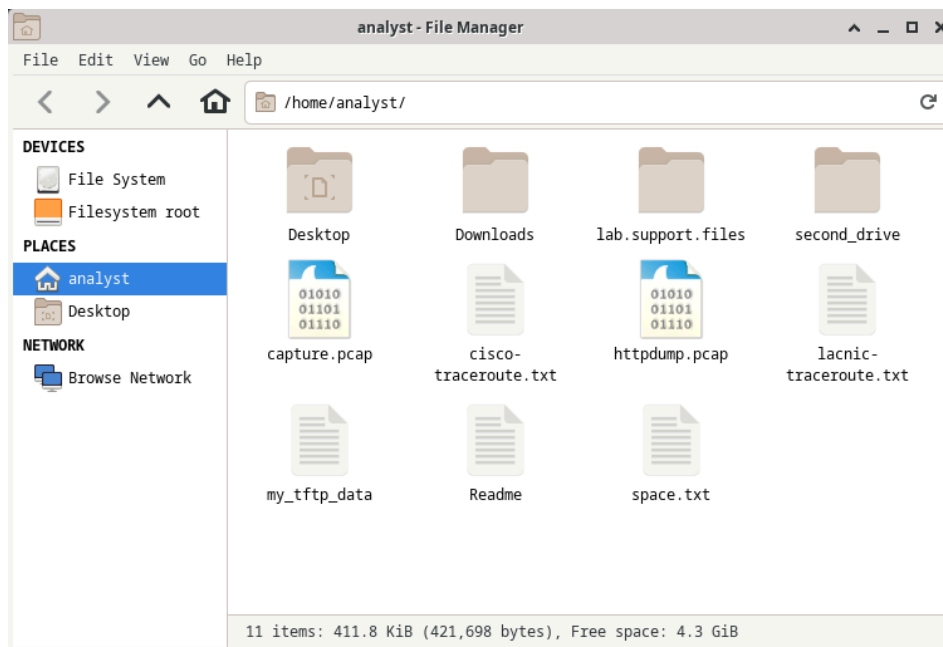
Оскільки цей веб-сайт використовує HTTP, трафік не шифрується. Клацніть на поле Пароль (Password), щоб побачити спливаюче попередження.

- e. Введіть ім'я користувача **Admin** з паролем **Admin** і натисніть **Login (Увійти)**.
- f. Закрийте веб-браузер.
- g. Поверніться до вікна терміналу, де запущено tcpdump. Введіть **CTRL+C**, щоб зупинити захоплення пакетів.

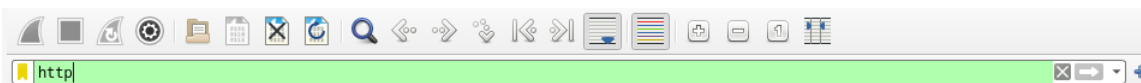
Крок 3: Перегляньте захоплення HTTP.

Tcpdump, виконаний на попередньому кроці, записав вихідні дані у файл з ім'ям httpdump.pcap. Цей файл знаходиться в домашньому каталозі користувача **analyst**.

- а. Клацніть на піктограмі File Manager (Диспетчер файлів) на робочому столі та перейдіть до домашнього каталогу користувача **analyst**. Двічі клацніть на файлі **httpdump.pcap**, у діалоговому вікні Open With (Відкрити за допомогою) прокрутіть вниз до Wireshark і натисніть кнопку **Open (Відкрити)**.



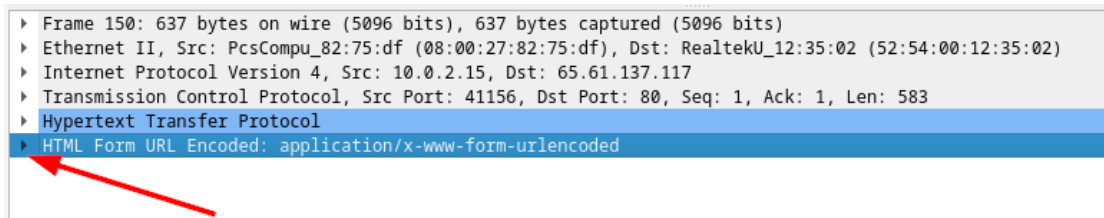
- б. У застосунку Wireshark відфільтруйте **http** і натисніть **Apply (Застосувати)**.



- с. Перегляньте різні HTTP-повідомлення та виберіть повідомлення **POST**.

No.	Time	Source	Destination	Protocol	Length	Info
44	7.806931	10.0.2.15	65.61.137.117	HTTP	399	GET /bank/login.jsp HTTP/1.1
46	7.879473	65.61.137.117	10.0.2.15	HTTP	256	HTTP/1.1 302 Found
48	7.987694	10.0.2.15	65.61.137.117	HTTP	447	GET /login.jsp HTTP/1.1
54	8.062632	65.61.137.117	10.0.2.15	HTTP	3228	HTTP/1.1 200 OK (text/html)
81	8.276625	10.0.2.15	65.61.137.117	HTTP	409	GET /style.css HTTP/1.1
89	8.349119	65.61.137.117	10.0.2.15	HTTP	1532	HTTP/1.1 200 OK (text/css)
150	20.856396	10.0.2.15	65.61.137.117	HTTP	637	POST /doLogin HTTP/1.1 (application/x-www-form-urlencoded)
154	20.936367	65.61.137.117	10.0.2.15	HTTP	303	HTTP/1.1 302 Found
156	20.942993	10.0.2.15	65.61.137.117	HTTP	594	GET /bank/main.jsp HTTP/1.1
162	21.027105	65.61.137.117	10.0.2.15	HTTP	2326	HTTP/1.1 200 OK (text/html)

- d. У нижньому вікні відображаються повідомлення. Розгорніть розділ **HTML Form URL Encoded: application/x-www-form-urlencoded**.



Які два фрагменти інформації відображаються?

*У розділі "HTML Form URL Encoded" у Wireshark відображаються ім'я користувача (**uid**) та пароль (**passw**), які були введені на сайті. Вони передаються у відкритому, незашифрованому вигляді.*

- a. Закрийте програму Wireshark.

Частина 2: Захоплення та перегляд трафіку HTTPS

Тепер ви використовуватимете tcpdump із командного рядка робочої станції Linux для захоплення трафіку HTTPS. Після запуску tcpdump ви будете генерувати трафік HTTPS, а tcpdump записуватиме вміст мережевого трафіку. Ці записи знову буде проаналізовано за допомогою Wireshark.

Крок 1: Запустіть tcpdump у терміналі.

- a. Перебуваючи в застосунку терміналу, введіть команду **sudo tcpdump -i enp0s3 -s 0 -w httpsdump.pcap**. Коли буде запропоновано, введіть пароль **cyberops** для користувача analyst.

```
[analyst@secOps ~]$ sudo tcpdump -i enp0s3 -s 0 -w httpsdump.pcap
[sudo] password for analyst:
tcpdump: listening on enp0s3, link-type EN10MB (Ethernet), capture size 262144 bytes
```

Ця команда запускає tcpdump і записує мережевий трафік на інтерфейсі **enp0s3** робочої станції Linux. Якщо ваш інтерфейс відрізняється від enp0s3, будь ласка, змініть його при використанні вищевказаної команди.

Весь записаний трафік буде занесено в файл **httpsdump.pcap** в домашньому каталозі користувача analyst.

- b. Відкрийте веб-браузер з панелі запуску в VM робочої станції CyberOps. Перейдіть на сторінку www.netacad.com.

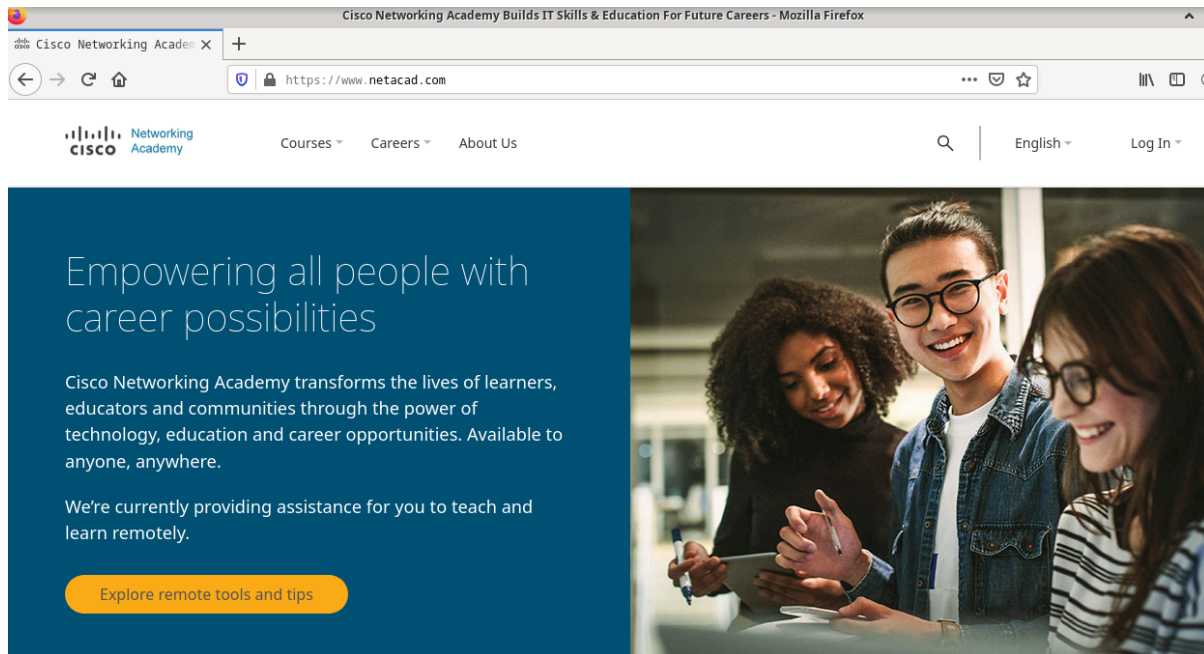
Примітка: Якщо ви отримали веб-сторінку «Secure Connection Failed (Помилка безпечного з'єднання)», ймовірно, це означає, що дата й час неправильні. Оновіть день і час за допомогою такої команди, змінивши поточний день і час:

```
[analyst@secOps ~]$ sudo date -s "12 MAY 2020 21:38:20"
```

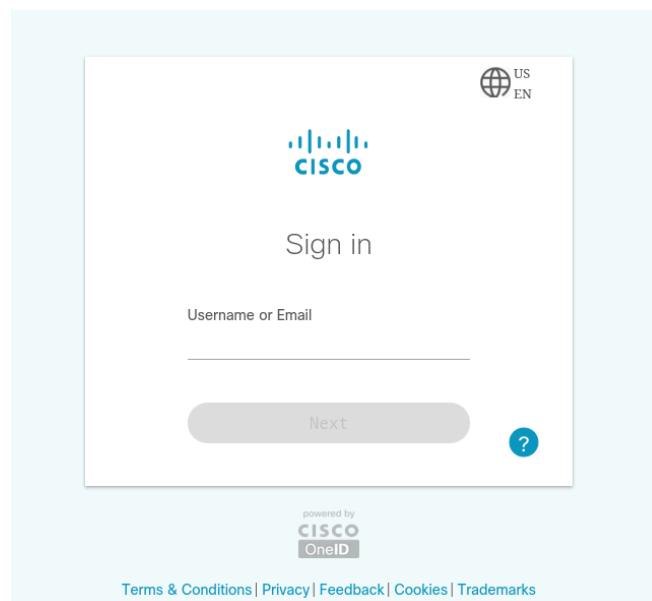
Що ви помітили в URL-адресі веб-сайту?

URL-адреса починається з <https://> замість <http://>. Також в адресному рядку браузера з'являється значок замка, що вказує на безпечне, зашифроване з'єднання.

с. Натисніть **Log in (Увійти)**.



d. Введіть свої ім'я користувача та пароль для NetaCAD. Натисніть **Next (Далі)**.



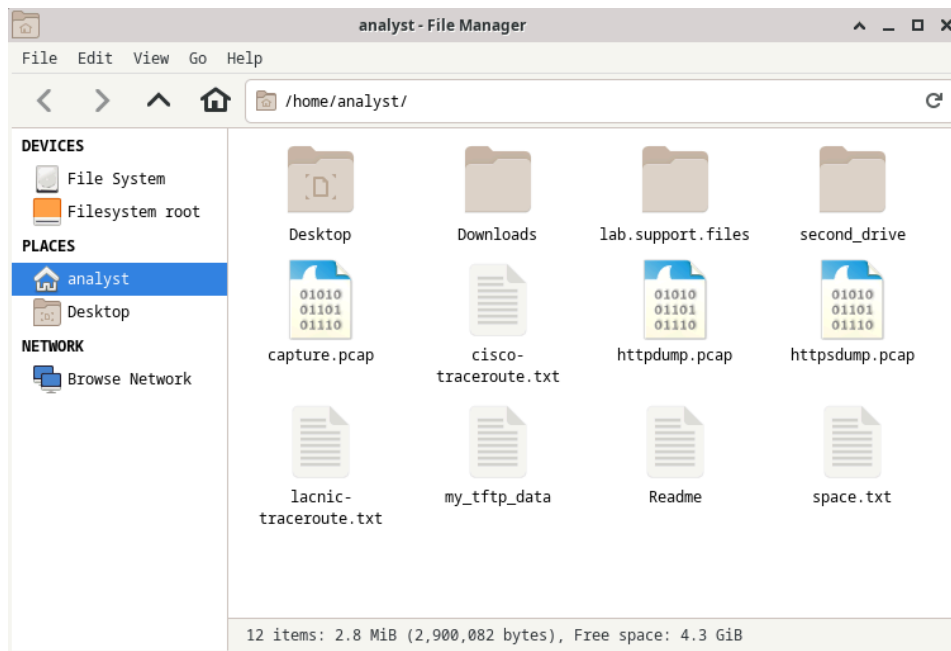
е. Закрийте веб-браузер у віртуальній машині.

ф. Поверніться до вікна терміналу, де запущено tcpdump. Введіть **CTRL+C**, щоб зупинити захоплення пакетів.

Крок 2: Перегляньте захоплення HTTPS.

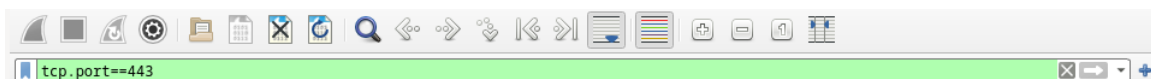
Tcpdump, виконаний на кроці 1, записав вихідні дані до файлу з назвою httpsdump.pcap. Цей файл знаходиться в домашньому каталозі користувача **analyst**.

- а. Клацніть на піктограму Filesystem (Файлова система) на робочому столі та перейдіть до домашнього каталогу для користувача analyst. Відкрийте файл **httpsdump.pcap**.

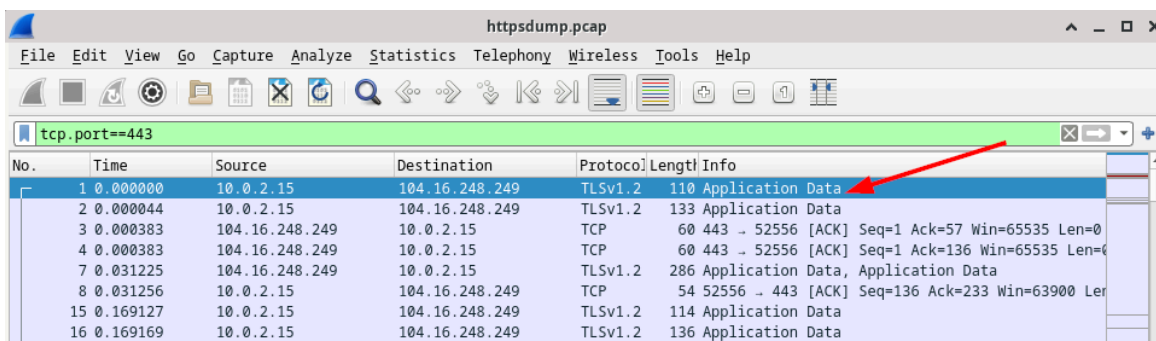


- б. У програмі Wireshark розгорніть вікно захоплення по вертикалі, а потім відфільтруйте трафік HTTPS через порт 443.

Введіть **tcp.port==443** як фільтр і натисніть кнопку **Apply (Застосувати)**.



- с. Перегляньте різні повідомлення HTTPS і виберіть повідомлення **Application Data (Дані програми)**.



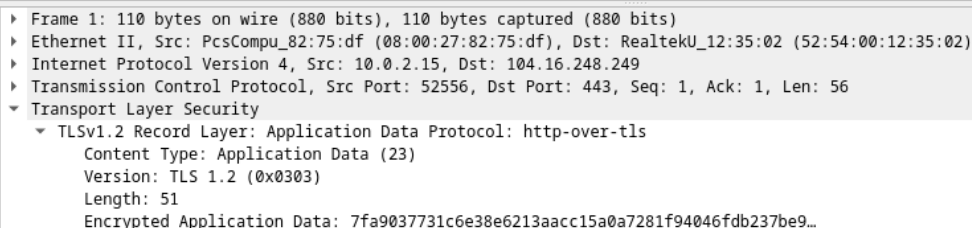
- д. У нижньому вікні відображаються повідомлення.

Запитання:

Що замінило розділ HTTP, який був у попередньому файлі захоплення?

Розділ HTTP був замінений протоколом Transport Layer Security (TLS), також відомим як Secure Sockets Layer (SSL). Цей протокол відповідає за шифрування даних.

е. Повністю розгорніть розділ **Secure Sockets Layer**.



```
▶ Frame 1: 110 bytes on wire (880 bits), 110 bytes captured (880 bits)
▶ Ethernet II, Src: PcsCompu_82:75:df (08:00:27:82:75:df), Dst: RealtekU_12:35:02 (52:54:00:12:35:02)
▶ Internet Protocol Version 4, Src: 10.0.2.15, Dst: 104.16.248.249
▶ Transmission Control Protocol, Src Port: 52556, Dst Port: 443, Seq: 1, Ack: 1, Len: 56
▼ Transport Layer Security
  ▼ TLSv1.2 Record Layer: Application Data Protocol: http-over-tls
    Content Type: Application Data (23)
    Version: TLS 1.2 (0x0303)
    Length: 51
    Encrypted Application Data: 7fa9037731c6e38e6213aacc15a0a7281f94046fdb237be9...
```

ф. Натисніть кнопку **Encrypted Application Data (Зашифровані дані програми)**.

Запитання:
Чи є дані програми у відкритому текстовому чи читабельному форматі?

Ні. Дані програми повністю зашифровані і виглядають як набір випадкових, нечитабельних символів.

а. Закрийте всі вікна і вимкніть віртуальну машину.

Питання для самоперевірки

1. Які переваги використання HTTPS замість HTTP?

Конфіденційність: Дані, що передаються (логіни, паролі, номери карток), шифруються, і їх неможливо прочитати, якщо їх перехопити.

Цілісність: Захищає дані від змін під час передачі.

Автентифікація: Перевіряє, що ви підключаєтеся саме до того сервера, за який він себе видає, захищаючи від атак "людина посередині".

2. Чи всі веб-сайти, які використовують HTTPS, вважаються надійними?

Ні. Як зазначено в лабораторній роботі, HTTPS гарантує лише те, що ваше з'єднання з сервером зашифроване. Він не гарантує, що сам сайт є безпечним або надійним. Зловмисники також можуть використовувати HTTPS для створення фішингових або шкідливих сайтів, щоб приховати свою діяльність та викликати у користувачів хибне відчуття безпеки.